COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.1 · Wireless Security Settings

Mestre CyberSec · **Aula 4.1 — Wireless Security Settings** (10:54) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** Config do AP: WPA3/SAE (moderno), WPA2/TKIP e WEP quebrados proibidos; RADIUS centralizado; WPS (Wi-Fi Protected Setup) inseguro — DISABLE.

💡 Highlights que a prova CompTIA cobra

- WPA3/SAE = moderno; WEP/WPA nunca
- WPS (o botãozinho) é INSEGURO — desabilita sempre

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'deprecate WEP/WPA'=use WPA2/3

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.1 — Wireless Security Settings)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• WPA3 (Acesso Protegido Wi-Fi 3)

O padrão moderno atual de segurança wireless que usa SAE (Autenticação Simultânea de Iguais) para autenticação baseada em senha, fornecendo proteção contra ataques de dicionário offline e sigilo direto (forward secrecy).

⚠️ ***Armadilha CompTIA:*** *On the exam, WPA3 is always the BEST/correct answer when available; if WPA3 is mentioned as an option, choose it over WPA2.*

• SAE (Autenticação Simultânea de Iguais)

Mecanismo seguro de troca de chaves usado no WPA3 que substitui o handshake de 4 vias do WPA2, impedindo ataques de dicionário/Força-bruta offline ao exigir um handshake ativo para cada tentativa de senha.

⚠️ ***Armadilha CompTIA:*** *When the question describes a WPA3 attack mitigation for offline brute-force, the answer is SAE (not just WPA3 generically).*

• WPA2 (Acesso Protegido Wi-Fi 2)

O padrão de segurança wireless da geração anterior usando PSK (Personal) ou 802.1X (Enterprise) com criptografia AES-CCMP; ainda aceitável, mas considerado legado em comparação ao WPA3.

⚠️ ***Armadilha CompTIA:*** *WPA2 with AES-CCMP is acceptable; WPA2 with TKIP is DEPRECATED — never choose TKIP as an encryption method on the exam.*

• TKIP (Protocolo de Integridade de Chave Temporal)

Um protocolo de criptografia mais antigo usado com WPA/WPA2 que foi descontinuado devido a vulnerabilidades; substituído pelo mais seguro AES-CCMP.

⚠️ ***Armadilha CompTIA:*** *TKIP is a DEPRECATED/INSECURE option. If you see TKIP as an answer choice on the exam, it is a distractor — choose AES-CCMP or SAE instead.*

• WEP (Privacidade Equivalente à Cabeada)

O protocolo original de segurança wireless, agora completamente quebrado e quebrável em segundos; NUNCA deve ser usado em nenhum ambiente moderno.

⚠️ ***Armadilha CompTIA:*** *Any question mentioning WEP = 'deprecate/disable immediately.' It is the WORST answer for wireless security; migrating to WPA2/WPA3 is required.*

• RADIUS (Serviço Remoto de Autenticação de Usuário)

Protocolo centralizado de servidor AAA (Autenticação, Autorização e Accounting) usado com 802.1X para autenticação wireless Enterprise, fornecendo credenciais por usuário escaláveis em vez de uma PSK compartilhada.

⚠️ ***Armadilha CompTIA:*** *When the scenario says 'centralized wireless authentication for an enterprise,' the answer is WPA2/WPA3 Enterprise with RADIUS + 802.1X, NOT PSK.*

- **802.1X**

Padrão de Controle de Acesso à Rede (NAC) baseado em porta que autentica dispositivos/usuários que se conectam a uma rede cabeada ou wireless via um autenticador (AP) e servidor de autenticação (RADIUS).

⚠️ ***Armadilha CompTIA:*** *Distinguish Personal mode (PSK/shared key) vs Enterprise mode (802.1X + RADIUS + per-user). Enterprise is always preferred for corporate environments.*

- **WPS (Configuração Protegida Wi-Fi)**

Recurso de conveniência que simplifica a conexão de dispositivos a uma rede Wi-Fi via PIN ou botão de pressão; considerado altamente inseguro e vulnerável a ataques de força-bruta no PIN de 8 dígitos.

⚠️ ***Armadilha CompTIA:*** *ALWAYS DISABLE WPS on every AP — Professor Messer's #1 wireless hardening tip. The push-button/PIN feature is a guaranteed exam trap.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 WPA3 e o Mecanismo SAE (Simultaneous Authentication of Equals)

🏠 **Analogia Intuitiva:** No WPA2 clássico, um hacker no estacionamento grava o áudio do seu aperto de mão ao conectar no Wi-Fi, vai para casa e usa supercomputadores para testar 100 milhões de senhas por segundo offline sem você saber. No WPA3 com SAE, o interfone exige uma conversa matemática ao vivo e exclusiva para cada tentativa de senha: o hacker é obrigado a falar com o roteador a cada chute, tornando ataques de dicionário offline fisicamente impossíveis.

🔍 **Causa Raiz / Por que foi criado:** O 4-way handshake do WPA2 utiliza a chave pré-compartilhada (PSK) diretamente no cálculo de derivação de chaves sem sigilo de encaminhamento (forward secrecy). O SAE introduz o protocolo Dragonfly, garantindo autenticação mútua resistente a escuta passiva.

🛡️ **Visão do Auditor de GRC:** Exigência de migração mandatória de redes Wi-Fi corporativas para WPA3-Enterprise ou WPA3-Personal; auditoria da desativação do suporte legado de transição (WPA3-only em áreas de alta confidencialidade) e validação de criptografia de 192 bits (Suite B).

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: "technology that prevents offline dictionary and brute-force attacks against captured wireless handshakes" = SAE (Simultaneous Authentication of Equals) / WPA3.

📌 WPA2/WPA3-Enterprise (802.1X + RADIUS) vs. PSK (Senha Compartilhada)

🏠 **Analogia Intuitiva:** O modo Personal (PSK) é como dar a mesma chave física da porta da frente para 500 funcionários: se um for demitido, você precisa trocar a fechadura do prédio inteiro e fazer 500 chaves novas. O modo Enterprise (802.1X + RADIUS) é uma catraca eletrônica com crachá individual: cada colaborador usa seu próprio login e senha. Se alguém for desligado da empresa, a portaria revoga apenas o crachá dele no servidor central, e todos os outros continuam trabalhando sem interrupção.

🔍 **Causa Raiz / Por que foi criado:** Senhas compartilhadas (PSK) impedem a identificação individual (Accounting/Auditoria) e causam colapso operacional no desligamento de funcionários. O padrão IEEE 802.1X integra o AP a servidores de autenticação AAA (RADIUS/TACACS+), viabilizando credenciais exclusivas e certificados EAP-TLS.

🛡️ **Visão do Auditor de GRC:** Auditoria de conformidade com padrões PCI-DSS e ISO 27001 que proíbem senhas compartilhadas em redes corporativas; inspeção da integração entre controladoras Wi-Fi e diretórios Active Directory/LDAP via RADIUS seguro (802.1X).

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: "centralized wireless authentication where each user connects using their own unique credentials and access can be revoked individually" = WPA2/WPA3-Enterprise (802.1X / RADIUS).

📌 Desativação Mandatória de WPS (Wi-Fi Protected Setup) e Protocolos Quebrados (WEP/TKIP)

🏠 **Analogia Intuitiva:** Ter um cofre de banco com porta de aço de 20 toneladas, mas deixar um botãozinho de campainha de plástico na calçada com um PIN de 4 dígitos que abre a porta se alguém chutar números por 2 horas. O WPS é exatamente isso: uma conveniência doméstica perigosa. Da mesma forma, usar WEP ou WPA-TKIP é como usar um cadeado de brinquedo que qualquer criminoso abre com um grampo de cabelo em 15 segundos.

🔍 **Causa Raiz / Por que foi criado:** O PIN de 8 dígitos do WPS é verificado pela controladora dividindo-o em duas metades (4 dígitos e 3 dígitos + checksum), reduzindo o espaço amostral de 100 milhões para apenas 11.000 tentativas (quebrável em minutos com ferramentas como Reaver). Já o WEP sofre de fraqueza fatal nos Vetores de Inicialização (IV de 24 bits), e o TKIP foi depreciado por falhas criptográficas.

🛡️ **Visão do Auditor de GRC:** Auditoria técnica com varreduras ativas de RF para confirmar desativação global do WPS em todos os Access Points; bloqueio de cifras depreciadas (WEP e TKIP) na política corporativa de segurança da informação (AUP).

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: "insecure quick-connect wireless feature using an 8-digit PIN vulnerable to brute-force that should ALWAYS be disabled" = WPS. "Deprecated wireless cipher that should NEVER be used" = WEP ou TKIP.

📌 Contenção de Sinal de RF: Ajuste de Potência e Seleção de Antenas

🏠 **Analogia Intuitiva:** Falar em tom de conversa calmo dentro de uma sala de reuniões com paredes de vidro em vez de gritar no megafone com som vazando para o estacionamento e a calçada. Ajustar a potência de transmissão (*Transmit Power*) evita que espiões na rua acessem a rede. E se precisar ligar dois prédios distantes, em vez de uma lâmpada que ilumina tudo (antena omnidirecional), você usa um raio laser reto e focado (antena direcional Yagi ou parabólica).

🔍 **Causa Raiz / Por que foi criado:** APs novos saem de fábrica operando em 100% de potência por padrão, irradiando sinal de RF para fora do perímetro físico e facilitando wardriving. A escolha incorreta de antenas omnidirecionais para enlaces ponto a ponto dispersa 80% da energia eletromagnética.

🛡️ **Visão do Auditor de GRC:** Inspeção de mapas de calor (heatmaps) gerados por site surveys para auditar vazamento de RF nos limites perimetrais da organização; conferência de especificações técnicas de antenas direcionais em pontes externas.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: "prevent wireless signal from bleeding outside the facility into adjacent public parking areas" = Reduce transmit power. "Point-to-point wireless bridge between two buildings" = Directional antenna.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Eliminar ataques de dicionário e força bruta offline contra handshakes capturados no Wi-Fi	**WPA3 com SAE (Simultaneous Authentication of Equals)**
Autenticação sem fio centralizada corporativa com credenciais individuais e revogação imediata	**WPA2/WPA3-Enterprise (802.1X + RADIUS)**
Recurso de configuração rápida com PIN de 8 dígitos vulnerável a força bruta que deve ser desabilitado	**WPS (Wi-Fi Protected Setup)**
Protocolo e cifra legados totalmente quebrados que devem ser desativados imediatamente em qualquer rede	**WEP e WPA-TKIP (Depreciados)**
Impedir que o sinal de rádio Wi-Fi vaze para a calçada ou estacionamento público da empresa	**Redução da Potência de Transmissão (Transmit Power Reduction)**
Conectar dois prédios corporativos separados por uma avenida através de enlace sem fio focado	**Antena Direcional (Yagi / Parabólica)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um hospital está renovando sua infraestrutura sem fio. A equipe de segurança quer eliminar o risco de ataques de dicionário offline contra handshakes capturados do WPA2-Personal para a SSID de convidados. Qual configuração de segurança sem fio deve ser definida nos APs para a SSID de convidados?

A) WPA2-Personal com AES-CCMP

B) WPA2-Enterprise com PEAP-MSCHAPv2

C) WPA3-Personal com SAE

D) Autenticação aberta com portal cativo

QUESTÃO 2 · CENÁRIO DE EXAME

Os novos leitores de código de barras sem fio de uma empresa de logística só suportam WPA2-Personal com TKIP. A política de segurança proíbe TKIP por ser criptograficamente fraco. O que o administrador deve fazer?

A) Substituir ou atualizar os leitores para que suportem AES-CCMP ou WPA3 e, em seguida, desativar o TKIP.

B) Ativar modo misto WPA2/WPA3 com TKIP para os leitores eliminando pontos únicos de falha operacional

C) Configurar uma SSID oculta com filtragem MAC para os leitores em todos os clusters híbridos locais e em nuvem

D) Configurar o AP com WEP para compatibilidade dos leitores e segmentá-los em uma VLAN sem interromper a disponibilidade das cargas de produção

QUESTÃO 3 · CENÁRIO DE EXAME

Uma loja de varejo ainda usa WEP em um AP para coletores de inventário antigos. Uma avaliação recente classifica o WEP como achado crítico. Qual ação corrige melhor o achado?

A) Aumentar o comprimento da chave WEP de 64 bits para 128 bits eliminando pontos únicos de falha operacional

B) Migrar os coletores para WPA2/WPA3 e desativar o WEP no AP.

C) Trocar a chave WEP semanalmente sem interromper a disponibilidade das cargas de produção

D) Ocultar a SSID e reduzir a potência de transmissão aplicando menor privilégio e reduzindo superfícies de ataque

QUESTÃO 4 · CENÁRIO DE EXAME

Uma universidade quer que cada aluno e funcionário se autentique no Wi-Fi com credenciais individuais. A equipe de segurança também precisa de contabilização centralizada e da capacidade de revogar o acesso de um usuário sem alterar uma chave compartilhada. Qual configuração de AP deve ser usada?

A) WPA3-Personal com SAE em todos os clusters híbridos locais e em nuvem

B) WPA2-Personal com uma longa frase secreta compartilhada

C) WPS com configuração por botão aplicando menor privilégio e reduzindo superfícies de ataque

D) WPA2-Enterprise com 802.1X e RADIUS

QUESTÃO 5 · CENÁRIO DE EXAME

Uma pequena empresa habilita WPS no AP para permitir que os funcionários conectem impressoras facilmente. Um auditor alerta que o método PIN pode ser quebrado por força bruta. Qual recomendação é mais apropriada?

A) Desativar o WPS e usar WPA3 ou WPA2 com credenciais fortes ou 802.1X.

B) Alterar o PIN do WPS a cada 30 dias aplicando menor privilégio e reduzindo superfícies de ataque

C) Usar WPS por botão apenas durante o horário comercial através de pipelines automatizados de configuração

D) Restringir WPS aos endereços MAC das impressoras assegurando conformidade rigorosa de retenção de logs

QUESTÃO 6 · CENÁRIO DE EXAME

Uma empresa teme que atacantes que obtiverem a frase secreta do Wi-Fi consigam conectar laptops não autorizados à SSID corporativa. A equipe de rede deve garantir que apenas dispositivos gerenciados pelo domínio possam entrar. Qual configuração atende melhor a esse requisito?

A) WPA3-Personal com SAE e uma frase secreta complexa.

B) SSID oculta com potência de sinal reduzida através de pipelines automatizados de configuração

C) WPA2-Enterprise com 802.1X, EAP-TLS e RADIUS.

D) WPA2-Personal com filtragem de endereço MAC utilizando perfis padronizados de automação de segurança

QUESTÃO 7 · CENÁRIO DE EXAME

Uma organização quer implantar WPA3, mas precisa suportar tablets antigos somente WPA2 por seis meses. Qual abordagem de implantação é mais apropriada durante a transição?

A) WPA2 com TKIP porque é compatível com clientes WPA3 através de pipelines automatizados de configuração

B) Modo somente WPA3 para forçar a substituição imediata assegurando conformidade rigorosa de retenção de logs

C) WEP com 802.1X porque suporta ambos os tipos de cliente utilizando perfis padronizados de automação de segurança

D) Modo misto WPA3/WPA2 enquanto planeja aposentar dispositivos somente WPA2.

QUESTÃO 8 · CENÁRIO DE EXAME

Um analista de segurança captura um handshake de quatro vias do WPA2-Personal e tenta quebrá-lo offline. O diretor de TI pergunta qual upgrade mitiga diretamente esse ataque. Qual tecnologia deve ser recomendada?

A) TKIP em WPA2-Personal

B) SAE em WPA3-Personal

C) RADIUS com PAP prevenindo desvios não autorizados de configuração nos nós

D) PIN do WPS em todos os endpoints corporativos gerenciados

QUESTÃO 9 · CENÁRIO DE EXAME

Um administrador de rede está configurando um novo AP para usar 802.1X. O servidor RADIUS já está em execução. Qual etapa deve ser realizada no AP?

A) Configurar o AP como cliente RADIUS e especificar o endereço do servidor RADIUS e o segredo compartilhado.

B) Configurar uma única chave pré-compartilhada para todos os usuários do RADIUS prevenindo desvios não autorizados de configuração nos nós

C) Ativar WPS para que os clientes recebam o certificado RADIUS em todos os endpoints corporativos gerenciados

D) Definir o AP para WEP e mapear usuários para VLANs mantendo telemetria e monitoramento contínuos

QUESTÃO 10 · CENÁRIO DE EXAME

A política sem fio de uma empresa afirma que nenhum protocolo de criptografia obsoleto pode ser usado em APs corporativos. Durante uma auditoria, o administrador encontra um AP transmitindo uma rede WPA2 com TKIP habilitado. Qual é a melhor ação corretiva?

A) Ativar WPS para simplificar a reconexão dos clientes após a mudança.

B) Mover o AP para uma VLAN de convidados e manter TKIP para compatibilidade.

C) Alterar o comprimento da chave TKIP para 256 bits mantendo telemetria e monitoramento contínuos

D) Desativar o TKIP e configurar AES-CCMP com WPA2 ou WPA3.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — WPA3-Personal com SAE

WPA3-Personal com SAE usa Simultaneous Authentication of Equals e resiste a ataques de dicionário offline em handshakes capturados. WPA2-Personal com AES-CCMP ainda usa uma frase secreta compartilhada e permanece vulnerável a captura e quebra offline. WPA2-Enterprise fornece autenticação individual, mas o cenário foca no risco de modo pessoal da SSID de convidados. Autenticação aberta com portal cativo não fornece criptografia sem fio.

Questão 2: Alternativa A — Substituir ou atualizar os leitores para que suportem AES-CCMP ou WPA3 e, em seguida, desativar o TKIP.

O TKIP é obsoleto e proibido, portanto não deve permanecer ativado apenas para dispositivos legados. A correção definitiva é substituir ou atualizar os leitores para suportarem AES-CCMP ou WPA3 e então desativar o TKIP. SSID oculta, filtragem MAC e WEP não corrigem a criptografia fraca, e o WEP é ainda menos seguro.

Questão 3: Alternativa B — Migrar os coletores para WPA2/WPA3 e desativar o WEP no AP.

O WEP é quebrado independentemente do comprimento ou da rotação da chave, então deve ser desativado. Migrar os coletores para WPA2 ou WPA3 e desativar o WEP corrige a causa raiz. Aumentar chave, rotacionar chaves, ocultar SSID e reduzir potência não corrigem as fraquezas criptográficas do WEP.

Questão 4: Alternativa D — WPA2-Enterprise com 802.1X e RADIUS

WPA2-Enterprise com 802.1X e RADIUS suporta autenticação individual de usuários, contabilização centralizada e revogação por usuário. WPA3-Personal e WPA2-Personal usam credenciais compartilhadas, então revogar um usuário exige alterar a chave compartilhada para todos. WPS é inseguro e não é um método de autenticação empresarial.

Questão 5: Alternativa A — Desativar o WPS e usar WPA3 ou WPA2 com credenciais fortes ou 802.1X.

O PIN do WPS é vulnerável a ataques de força bruta e deve ser desativado. A recomendação segura é desligar o WPS e usar WPA3/WPA2 com credenciais fortes ou 802.1X. Alterar o PIN, agendar o botão ou filtrar MAC não elimina a superfície de ataque do WPS.

Questão 6: Alternativa C — WPA2-Enterprise com 802.1X, EAP-TLS e RADIUS.

WPA2-Enterprise com 802.1X, EAP-TLS e RADIUS pode exigir certificados de dispositivo e validar cada dispositivo antes do acesso à rede. WPA3-Personal e WPA2-Personal dependem de credenciais compartilhadas, então qualquer pessoa com a frase secreta pode se conectar. SSID oculta e filtragem MAC são controles fracos que podem ser contornados.

Questão 7: Alternativa D — Modo misto WPA3/WPA2 enquanto planeja aposentar dispositivos somente WPA2.

O modo misto WPA3/WPA2 permite que clientes compatíveis com WPA3 usem WPA3 enquanto oferece suporte temporário a dispositivos somente WPA2. WPA2 com TKIP usa protocolo obsoleto, somente WPA3 quebraria os tablets imediatamente, e WEP com 802.1X não é uma combinação segura válida.

Questão 8: Alternativa B — SAE em WPA3-Personal

O SAE no WPA3-Personal substitui o handshake PSK do WPA2-Personal por uma troca de autenticação resistente, impedindo ataques de dicionário offline em handshakes capturados. TKIP é obsoleto, RADIUS com PAP é inseguro para credenciais, e o PIN do WPS é vulnerável a força bruta.

Questão 9: Alternativa A — Configurar o AP como cliente RADIUS e especificar o endereço do servidor RADIUS e o segredo compartilhado.

Para 802.1X, o AP atua como autenticador e deve ser configurado como cliente RADIUS com o endereço do servidor RADIUS e um segredo compartilhado. Uma única chave pré-compartilhada é WPA2-Personal, WPS é inseguro e não relacionado, e WEP não deve ser usado.

Questão 10: Alternativa D — Desativar o TKIP e configurar AES-CCMP com WPA2 ou WPA3.

O TKIP é um protocolo de criptografia obsoleto e deve ser removido dos APs corporativos. A ação correta é desativar o TKIP e usar AES-CCMP com WPA2 ou WPA3. Ativar WPS adiciona risco, mover para VLAN de convidados não corrige a criptografia fraca, e alterar o comprimento da chave TKIP não o torna aceitável.